

某APT组织攻击我国多个目标曝光

360-CERT 360CERT Yesterday



0x00 事件分析

2019年10月27日，推特@MisterCh0c发布一张照片，通过360CERT研究人员分析，发现该C2控制台隶属于某网军“蔓灵花”组织（Bitter），该后台控制界面中暴露多个我国IP地址被控制上线。控制台界面显示了木马控制后台的主机信息界面，包括最后上线时间、主机版本信息、用户名称、电脑名称等。

Statistics Systems Tasks Log Logout						
SNo	IP	Computer	User	Operating system	First Seen	Last Seen
☐ 1	106.11.11.0.5	ASHUR-SPC	Ashur-sPC	Windows 10 Pro	2019-09-23	2019-09-23 11:03:39
☐ 2	121.11.11.210	MOFCOM2934	mofcom2934	Windows 7 Ultimate	2019-09-26	2019-10-11 08:53:34
☐ 3	58.11.11.54	DESKTOP-BSPDD9L	DESKTOP-BSPDD9L	Windows 10 Education	2019-09-27	2019-10-24 08:15:44
☐ 4	66.11.11.127	WIN-VUA6POUV5UP	WIN-VUA6POUV5UP	Windows Server 2016 Standard	2019-10-04	2019-10-23 06:28:40
☐ 5	91.11.11.50	ACCOUNTS-PC	Accounts-PC	Windows 7 Professional	2019-10-05	2019-10-05 10:31:02
☐ 6	223.11.11.231	WHY-PC	why-PC	Windows 10 Pro	2019-10-09	2019-10-21 03:48:06
☐ 7	45.11.11.20	LAPTOP-E9JIPJCQ	LAPTOP-E9JIPJCQ	Windows 10 Home China	2019-10-10	2019-10-10 10:43:04
☐ 8	185.11.11.173	ADMIN-PC	Admin-PC	Windows 7 Professional	2019-10-16	2019-10-16 02:34:44
☐ 9	114.11.11.4	HUAWEI-PC	huawei-PC	Windows 7 Professional	2019-10-16	2019-10-21 07:52:23
☐ 10	65.11.11.100	CT-WINDOWSTHIN	CT-WindowsThin	Windows Embedded Standard	2019-10-17	2019-10-23 02:01:43
☐ 11	172.11.11.100	DIANNNEPC	DIANNNEPC	Windows%207%20Enterprise	2019-10-21	2019-10-21 06:42:25
☐ 12	61.11.11.204	HK-JK3234	hk-JK3234	Microsoft Windows XP	2019-10-23	2019-10-23 02:43:48

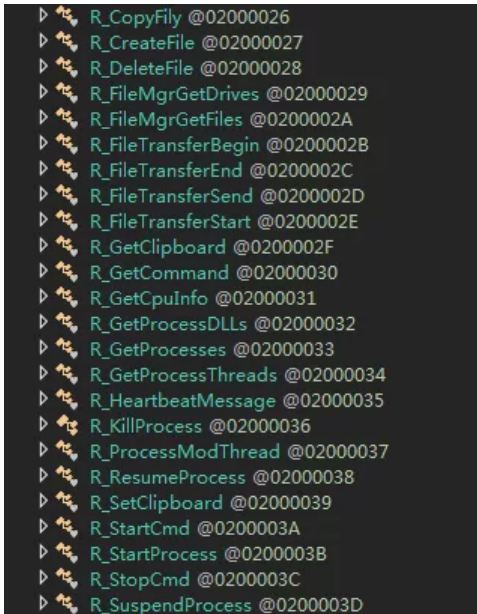
Submit Task

SelectGo

通过该控制页面，攻击者可以对目标继续下发任务，其功能特马如下：

 audiodq	文件	66 KB	否
 igfxsrvk	文件	68 KB	否
 kill	文件	11 KB	否
 lsap	文件	32 KB	否
 lsapc	文件	32 KB	否
 lsapcr	文件	33 KB	否
 MSAService7	文件	22 KB	否
 regdl	文件	11 KB	否
 sleep	文件	11 KB	否
 winsvc	文件	18 KB	否

- Audiodq：获取计算机基本信息，远程获取文件并执行
- igfxsrvk：键盘hook
- Kill：设置sleep文件开机自启
- Lsap、Lsapc、Lsapcr：磁盘、文件等相关操作
- MSAService7：采用C#编写，功能包括：文件创建拷贝删除与传输、进程的创建挂起结束及其相关信息、cmd命令、剪切板信息、计算机基本信息包括CPU信息，计算机名称、磁盘信息等。



Winsvc: 采用C语言编写的木马, 功能与上边类似

Sleep: 关机操作

regdl: 设置Audiodq开机自启

该C2链接地址为:

[http://lmhostsvc\[.\]net/healthne/](http://lmhostsvc[.]net/healthne/),

[IP: 162.222.215.134](#),

特马hash:

[FBC56C2DADAB05E78C995F57BF50BCE5](#)。

数据回传路径:

<http://lmhostsvc.net/healthne/accept.php?a=User-PC&b=USER-PC&c=Windows%20%20Professional&d=adminadmin90059c37-1320-41a4-b58d-2b75a9850d2f1565536040965860&e=abcd>。

相关样本anyrun分析地址:

<https://app.any.run/tasks/4c024e23-6738-470a-8676-b52e39462500/>

通过分析, 控制台页面展示的受害者有6台主机隶属于中国。

此次曝光的蔓灵花组织C2控制台仅仅揭露蔓灵花组织在我国攻击的冰山一角, 早在2017年末2018年初, 蔓灵花组织使用其常用的攻击手法攻击过我国多个部委、重要行业单位以及巴基斯坦在我国的工作人员, 影响单位和人员较多, 其使用的C2控制台与本次曝光的C2控制台完全一致。

蔓灵花 (BITTER) APT组织是一个长期针对中国、巴基斯坦等国家进行攻击活动的APT组织。近两年来, 蔓灵花APT组织并未更新其后台控制端以及特马的升级, 国内外多个安全研究组织都通过其后台漏洞进入到C2控制界面, 另外, 弱口令问题、目录遍历问题等常见WEB问题在该C2控制台均有漏洞体现。通过蔓灵花如此频繁的攻击活动, 我们可以看出某网军在网络情报获取方面一直采取积极主动的网络攻击的方式攫取情报, 我国是网络威胁中的受害者。

相关C2:

lmhostsvc[.]net

162.222.215.134

👍推荐阅读:

1、[更新]泛微e-cology OA数据库配置信息泄漏漏洞预警

2、CVE-2019-11043: PHP-FPM在Nginx特定配置下任意代码执行漏洞预警

3、安全客2019季刊第三季: 政企安全一漏洞运营与管理 正式发布!

长按下方二维码关注360CERT! 谢谢你的关注!



注：360CERT官方网站提供《某APT组织攻击我国多个目标曝光》完整详情，[点击阅读原文](#)

[Read more](#)